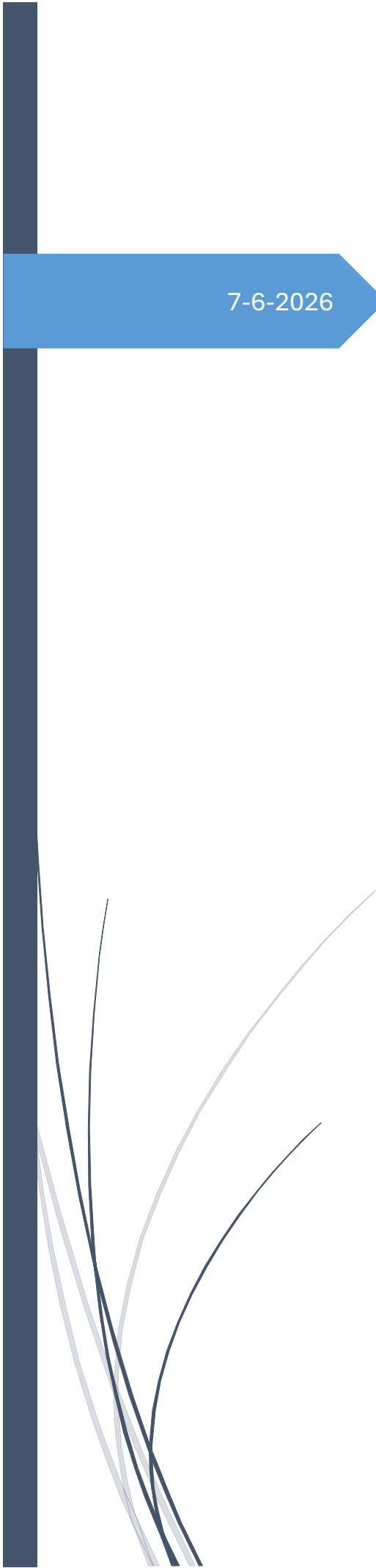


A thick dark blue vertical bar runs down the left side of the page. A blue arrow points to the right from this bar, containing the date. In the bottom left corner, several thin, curved lines in dark blue and light grey sweep upwards and to the right.

7-6-2026

Taller SoA con PILAR

Tienda de informática MACROSOFT S.L.

SAVU, RALUCA ALEXANDRA
CIPFP MISLATA

Contenido

1.	Supuesto práctico elegido.....	2
	Descripción del escenario	2
	Infraestructura tecnológica	2
	Datos de carácter personal relevantes.....	2
2.	Configuración de PILAR	3
	Opciones de configuración seleccionadas	3
3.	Fuentes de información	4
4.	Activos	5
	Activos esenciales [B].....	5
	Servicios internos [IS].....	5
	Equipamiento [E]	6
	Instalaciones [L].....	6
	Personal [P].....	6
5.	Dependencia de activos.....	7
6.	Valoración de activo.....	9
7.	Identificación de amenazas	10
8.	Valoración de amenazas.....	12
9.	Análisis de riesgos.....	15
10.	Análisis de impacto	19
11.	Salvaguardas	21
	Controles RGPD obligatorios	21
	Controles ISO/IEC 27001:2022.....	21
12.	Conclusión	23

1. Supuesto práctico elegido

Se ha seleccionado el Supuesto 2: Tienda de Informática MACROSOFT S.L., que presenta una combinación de vulnerabilidades técnicas, organizativas y legales.

Descripción del escenario

MACROSOFT S.L. es una tienda dedicada a la venta y reparación de equipos informáticos, componentes y software, ubicada en el barrio de La Coma de Paterna, zona considerada de alto riesgo. La plantilla está formada por el gerente (habitualmente fuera del local) y dos técnicos.

Infraestructura tecnológica

- 2 ordenadores con Windows 7 (sin soporte desde enero de 2020)
- Red WiFi con WPA2-PSK por defecto y WPS activado
- VPN PPTP para acceso remoto del gerente (protocolo obsoleto y vulnerable)
- Copias de seguridad irregulares en disco USB guardado en el local
- Sin alarma ni cámaras de vigilancia

Datos de carácter personal relevantes

Al reparar equipos, los técnicos tienen acceso a toda la información contenida en los discos duros de los clientes: fotos personales, documentos bancarios y contraseñas guardadas en navegadores. No existe contrato de encargado de tratamiento firmado con los clientes, lo que constituye una infracción directa del RGPD (Art. 28).

2. Configuración de PILAR

Se ha creado el proyecto en PILAR con la siguiente configuración:

Campo	Valor
Código del proyecto	MACRO
Nombre	Análisis de Riesgo - Tienda Informática MICROSOFT S.L.
Organización	MICROSOFT S.L.
Autor	Savu, Raluca Alexandra
Fecha	06/06/2026
Clasificación	DIFUSIÓN LIMITADA
Nivel de análisis	Medio
Biblioteca	[std] Biblioteca INFOSEC (22.7.2023)

Opciones de configuración seleccionadas

- Valoración: Activos + dependencias
- Probabilidad: MR, PP, P, MP, CS (escala cualitativa)
- Consecuencias: Porcentaje de degradación
- Amenazas: Manual (selección explícita por activo)

[MACRO] D. Proyecto > D.1. Datos del proyecto

biblioteca [std] Biblioteca INFOSEC (22.7.2023) (std_20251.pl5)

código [MACRO]

nombre [Análisis de Riesgo - Tienda Informática MICROSOFT S.L.]

proyecto - clasificación [DIFUSIÓN LIMITADA]

RGD [contexto]

código	nombre	valor
org	Organización	MICROSOFT S.L.
desc	Descripción	
author	Autor	Raluca Alexandra Savu
version	Versión	
date	Fecha	06/06/2026
owner	Responsable del Sistema	
ciso	Responsable de la Seguridad de la Información	

opciones

CAR: 2025.1

valoración

- ☒ activos + dependencias
- ☐ activos + dominios
- ☐ mix: activos + dependencias + dominios

probabilidad

- ☐ potencial (XS, S, M, L, XL)
- ☒ probabilidad (MR, PP, P, MP, CS)
- ☐ nivel (MB, B, M, A, MA)
- ☐ facilidad (F, M, D, MD, ED)
- ☐ ARO

consecuencias

- ☐ nivel
- ☒ porcentaje

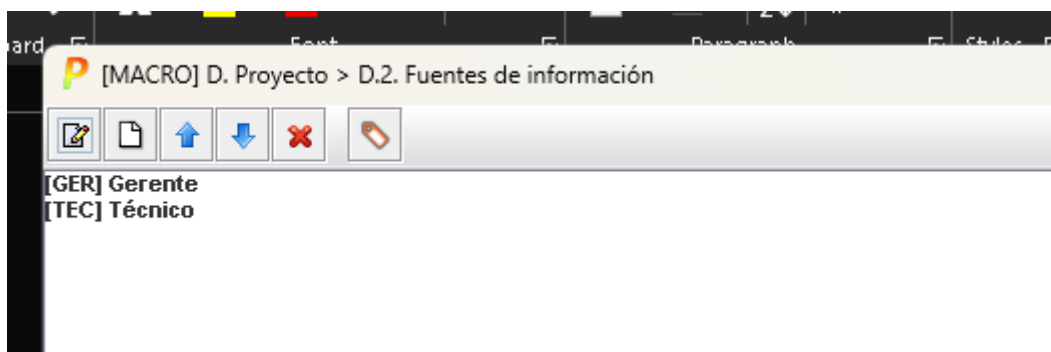
amenazas

- ☒ manual
- ☐ mix
- ☐ automático

3. Fuentes de información

Dado el reducido tamaño de la organización, no existen departamentos diferenciados. Las funciones de gestión, administración, soporte técnico y atención al cliente recaen únicamente en dos figuras. Se han definido las siguientes fuentes de información:

Código	Nombre	Justificación
GER	Gerente	Responsable del negocio, datos de clientes, proveedores, copias de seguridad y acceso remoto. Máxima autoridad sobre decisiones de seguridad.
TEC	Técnicos (x2)	Responsables de las operaciones diarias: reparaciones, ventas y manejo directo de los dispositivos y datos de los clientes.



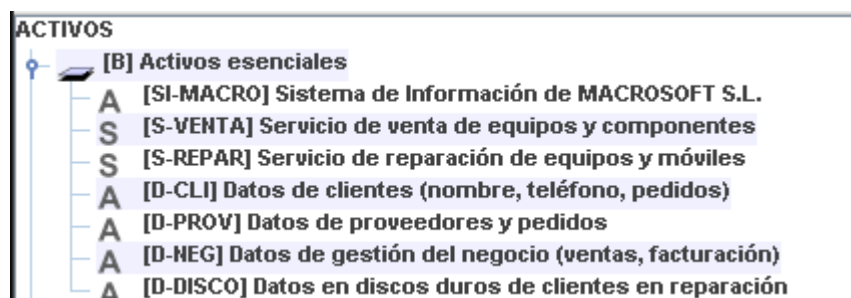
4. Activos

Se han identificado 25 activos distribuidos en las capas estándar de PILAR. A continuación, se describe cada capa con justificación de los activos incluidos.

Activos esenciales [B]

Los activos esenciales representan la razón de ser del sistema. En **MACROSOFT S.L.** se identifican tres tipos:

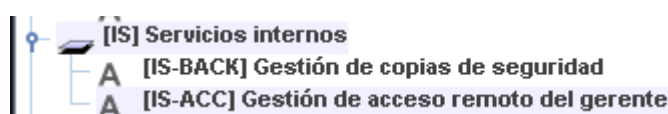
- El Sistema de Información (**SI-MACRO**) es el activo padre de todo el análisis. Representa el conjunto de sistemas TIC que soportan la actividad de la tienda.
- Los Servicios (S) son los servicios que la tienda ofrece a sus clientes: venta de equipos (**S-VENTA**) y reparación de dispositivos (**S-REPAR**). Ambos son críticos para la continuidad del negocio.
- Los Datos (D) son los activos más sensibles. **D-CLI** y **D-DISCO** contienen datos de carácter personal y están sujetos al RGPD. **D-NEG** y **D-PROV** contienen información comercial crítica del negocio.



Servicios internos [IS]

IS-BACK (Gestión de copias de seguridad): El gerente realiza copias cuando se acuerda, de forma irregular, en un disco USB guardado en el local. Esta dependencia de la memoria humana y la ausencia de procedimiento automatizado es una vulnerabilidad crítica.

IS-ACC (Gestión de acceso remoto): El gerente accede a los equipos de la tienda desde casa mediante VPN PPTP, un protocolo obsoleto y vulnerable, desde un equipo potencialmente infectado.



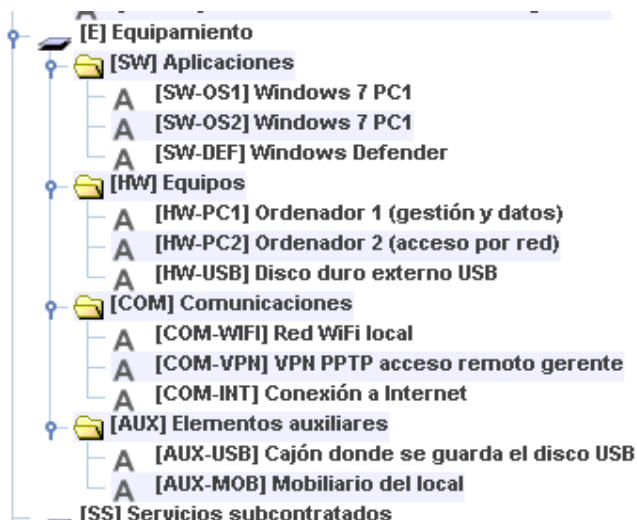
Equipamiento [E]

Software (SW): Windows 7 en ambos equipos (sin soporte desde 2020) y Windows Defender desactualizado. Esta combinación deja los sistemas sin protección efectiva frente a amenazas modernas.

Hardware (HW): PC1 contiene todos los datos del negocio. PC2 accede a ellos únicamente por red WiFi. El disco USB es el único soporte de copias de seguridad, guardado sin seguridad física.

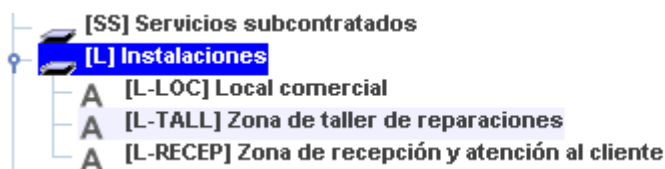
Comunicaciones (COM): La WiFi con credenciales por defecto y WPS activo es la vulnerabilidad de red más grave. La VPN PPTP añade riesgo en el acceso remoto.

Elementos auxiliares (AUX): El cajón donde se guarda el disco USB (AUX-USB) y el mobiliario del local (AUX-MOB).



Instalaciones [L]

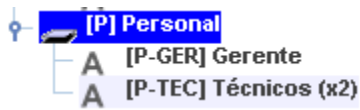
L-LOC es el local comercial en La Coma (Paterna), zona de alto riesgo sin alarma ni cámaras. **L-TALL** es la zona de taller donde los técnicos acceden a los discos de clientes. **L-RECEP** es la zona de atención al público.



Personal [P]

P-GER (Gerente): Habitualmente fuera del local. Único responsable de las copias de seguridad y el acceso remoto, creando un punto de fallo único. **P-TEC** (Técnicos x2):

Realizan ventas y reparaciones. Tienen acceso directo a los datos de clientes en reparación.

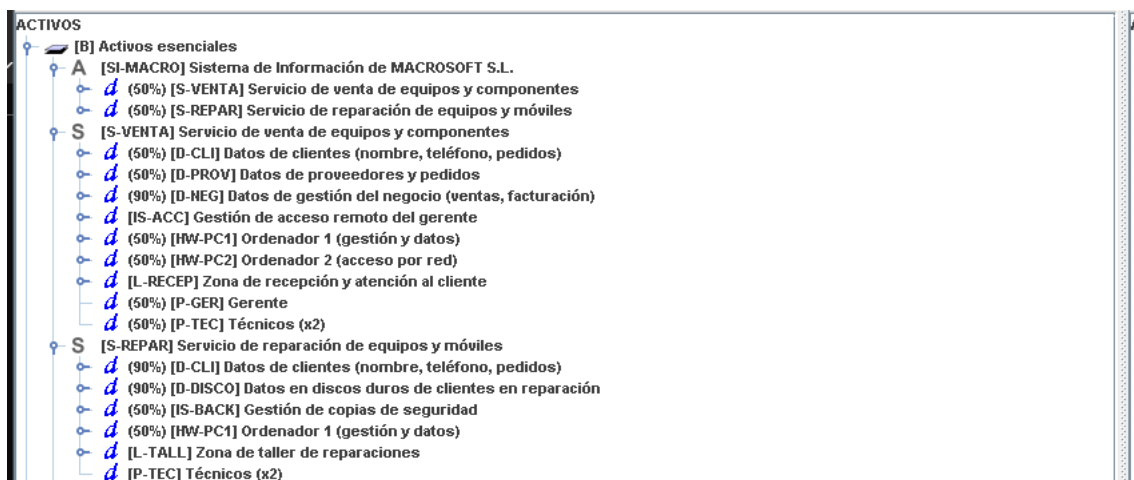


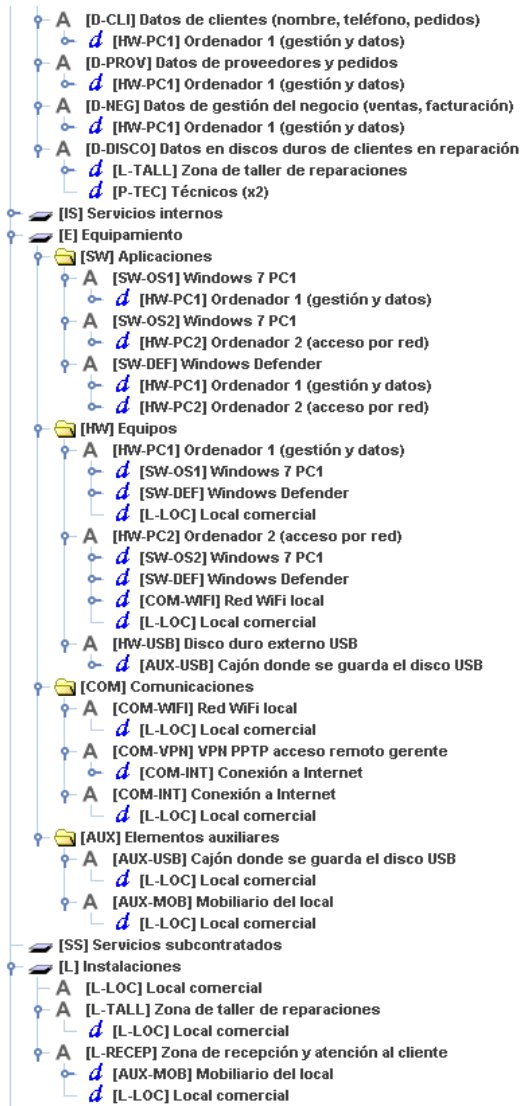
5. Dependencia de activos

Las dependencias reflejan cómo un incidente en un activo inferior (hijo) puede propagarse y afectar a activos de mayor nivel (padre). En PILAR, el valor del activo padre se calcula propagándose desde los hijos a través de estas dependencias.

Las dependencias más relevantes por justificar son:

Padre	Hijo	%	Justificación
SI-MACRO	S-REPAR	50%	El SI depende del servicio de reparaciones como actividad principal
SI-MACRO	S-VENTA	50%	El SI depende del servicio de ventas como actividad secundaria
S-REPAR	D-DISCO	90%	Las reparaciones requieren acceder a los discos de los clientes
S-REPAR	D-CLI	90%	Se necesitan los datos del cliente para gestionar cada reparación
S-REPAR	HW-PC1	50%	La gestión de reparaciones se realiza desde PC1
S-REPAR	P-TEC	100%	Sin técnicos no hay reparaciones posibles
HW-PC2	COM-WIFI	100%	PC2 accede a los datos ÚNICAMENTE a través de la red WiFi
IS-BACK	HW-USB	100%	Las copias se realizan en el disco USB exclusivamente
IS-BACK	P-GER	100%	El gerente es el único que realiza las copias de seguridad
D-CLI / D-NEG / D-PROV	HW-PC1	100%	Todos los datos del negocio están almacenados en PC1
COM-VPN	COM-INT	100%	La VPN necesita conexión a Internet para funcionar





6. Valoración de activo

Según los requisitos, se ha valorado únicamente el activo padre (**SI-MACRO**) en las cinco dimensiones de la seguridad. PILAR propaga automáticamente estos valores al resto de activos según las dependencias definidas.

La justificación de cada dimensión se basa en el contexto de la tienda:

Dimensión	Valor	Justificación
Confidencialidad [C]	[7] Alto	Datos personales de clientes y contenido de discos ajenos tratados sin contrato RGPD. Una fuga puede acarrear sanciones importantes.
Integridad [I]	[6] Alto(-)	Errores en pedidos o modificaciones no autorizadas en datos de reparaciones pueden causar pérdidas económicas y conflictos con clientes.
Disponibilidad [D]	[6] Alto(-)	PC1 es el punto único de fallo de toda la operativa del negocio. Su caída paraliza ventas y reparaciones.
Autenticidad [A]	[5] Medio(+)	Sin control de acceso robusto ni cuentas individuales, es difícil garantizar la autenticidad de los accesos.
Trazabilidad [T]	[4] Medio	No hay registros de auditoría ni logs de actividad. Es imposible saber quién accedió a qué datos y cuándo.

ACTIVOS	activo	[D]	[I]	[C]	[A]	[T]	[OP]
📁	[B] Activos esenciales						
📁	[SI-MACRO] Sistema de Información de MICROSOFT S.L.	[6]	[6]	[7]	[5]	[4]	
📁	[SI-PAV] Sistema de gestión de pedidos y ventas	[5]	[5]	[6]	[4]	[3]	
📁	[SI-SERPAR] Servicio de reparación de equipos y móviles	[5]	[5]	[6]	[4]	[3]	
📁	[D-CLI] Datos de clientes (nombre, teléfono, pedidos)	[5]	[5]	[6]	[4]	[3]	
📁	[D-PROV] Datos de proveedores y pedidos	[4]	[4]	[5]	[3]	[2]	
📁	[D-NEG] Datos de gestión del negocio (ventas, facturación)	[5]	[5]	[6]	[4]	[3]	
📁	[D-DISCO] Datos en discos duros de clientes en reparación	[5]	[5]	[6]	[4]	[3]	
📁	[IS] Servicios internos						
📁	[IS-BACK] Gestión de copias de seguridad	[4]	[4]	[5]	[3]	[2]	
📁	[IS-ACC] Gestión de acceso remoto del gerente	[5]	[5]	[6]	[4]	[3]	
📁	[E] Equipamiento						
📁	[SW] Aplicaciones						
📁	[SW-OS1] Windows 7 PC1	[6]	[6]	[7]	[5]	[4]	
📁	[SW-OS2] Windows 7 PC1	[6]	[6]	[7]	[5]	[4]	
📁	[SW-DEF] Windows Defender	[6]	[6]	[7]	[5]	[4]	
📁	[HW] Equipos						
📁	[HW-PC1] Ordenador 1 (gestión y datos)	[6]	[6]	[7]	[5]	[4]	
📁	[HW-PC2] Ordenador 2 (acceso por red)	[6]	[6]	[7]	[5]	[4]	
📁	[HW-USB] Disco duro externo USB	[4]	[4]	[5]	[3]	[2]	
📁	[COM] Comunicaciones						
📁	[COM-WIFI] Red WIFI local	[6]	[6]	[7]	[5]	[4]	
📁	[COM-VPN] VPN PPTP acceso remoto gerente	[5]	[5]	[6]	[4]	[3]	
📁	[COM-INT] Conexión a Internet	[5]	[5]	[6]	[4]	[3]	
📁	[AUX] Elementos auxiliares						
📁	[AUX-USB] Cajón donde se guarda el disco USB	[4]	[4]	[5]	[3]	[2]	
📁	[AUX-MOB] Mobiliario del local	[5]	[5]	[6]	[4]	[3]	
📁	[SS] Servicios subcontratados						
📁	[L] Instalaciones						
📁	[L-LOC] Local comercial	[6]	[6]	[7]	[5]	[4]	
📁	[L-TALL] Zona de taller de reparaciones	[6]	[6]	[7]	[5]	[4]	
📁	[L-RECEP] Zona de recepción y atención al cliente	[5]	[5]	[6]	[4]	[3]	
📁	[P] Personal						
📁	[P-GER] Gerente	[6]	[6]	[7]	[5]	[4]	
📁	[P-TEC] Técnicos (x2)	[6]	[6]	[7]	[5]	[4]	

7. Identificación de amenazas

Se ha asignado al menos una amenaza por activo, con un máximo de dos en los activos más críticos. Para los activos de carácter personal (D-CLI y D-DISCO) se han incluido amenazas de ámbito legal (RGPD).

Activo	Amenaza PILAR	Justificación
D-CLI	E.19 Fugas de información	Datos sin cifrar, acceso compartido sin autenticación individual
D-CLI - RGPD	PR.g10 Encargado sin garantías adecuadas	Sin contrato de encargado ni base legal clara para el tratamiento
D-DISCO	A.19 Revelación de información	Técnicos acceden a fotos, docs bancarios y contraseñas de clientes
D-DISCO - RGPD	PR.2n Accesos no autorizados a datos personales (lectura)	Sin contrato RGPD, el acceso a datos personales es ilegal
SW-OS1 / SW-OS2	E.20 Vulnerabilidades del software	Windows 7 sin soporte desde enero de 2020. Sin parches.
SW-DEF	E.20 Vulnerabilidades del software	Defender en W7 sin actualizaciones de firmas desde 2020
HW-PC1	A.11 Acceso no autorizado A.25 Robo de equipos	Sin contraseñas robustas + local en zona de alto riesgo sin alarma
HW-USB	A.25 Robo de equipos	Disco de copias guardado en cajón sin seguridad física
COM-WIFI	A.11 Acceso no autorizado E.2 Errores del administrador	WPA2-PSK por defecto + WPS activo. Nunca fue reconfigurada.
COM-VPN	A.5 Suplantación de identidad	PPTP obsoleto + PC del gerente posiblemente infectado
L-LOC	A.26 Ataque destructivo	Zona La Coma, Paterna: alto riesgo sin alarma ni cámaras
P-GER	A.28 Indisponibilidad del personal	Punto único de fallo para backups y acceso remoto
P-TEC	A.28 Indisponibilidad del personal	Sin técnicos no hay servicio de reparación ni venta

ACTIVOS	
[B] Activos esenciales	
A [SI-MACRO] Sistema de Información de MICROSOFT S.L.	
S [S-VENTA] Servicio de venta de equipos y componentes	
▲ [E.24] Caída del sistema por agotamiento de recursos	
S [S-REPAR] Servicio de reparación de equipos y móviles	
▲ [A.28] Indisponibilidad del personal	
A [D-CLI] Datos de clientes (nombre, teléfono, pedidos)	
▲ [E.19] Fugas de información	
▲ [PR.g10] 10. Seleccionar o mantener una relación con un encargado de tratamiento sin disponer de las garantías adecuadas	
A [D-PROV] Datos de proveedores y pedidos	
▲ [E.15] Alteración de la información	
A [D-NEG] Datos de gestión del negocio (ventas, facturación)	
▲ [E.18] Destrucción de la información	
A [D-DISCO] Datos en discos duros de clientes en reparación	
▲ [A.19] Revelación de información	
▲ [PR.2n] Accesos no autorizados a datos personales (lectura)	



8. Valoración de amenazas

Cada amenaza se ha valorado en dos dimensiones: la frecuencia de ocurrencia (escala cualitativa de PILAR) y la degradación que produce en cada dimensión de seguridad del activo afectado.

Activo	Amenaza	Frec.	[D]	[I]	[C]	[A]
[S-VENTA] Servicio de venta	[E.24] Caída del sistema por agotamiento de recursos	PP	50%	-	-	-
[S-REPAR] Servicio de reparación	[A.28] Indisponibilidad del personal	PP	75%	-	-	-
[D-CLI] Datos de clientes	[E.19] Fugas de información	MP	-	-	75%	-
[D-CLI] Datos de clientes	[PR.g10] Encargado sin garantías adecuadas - RGPD	P	-	-	100%	-
[D-PROV] Datos de proveedores	[E.15] Alteración de la información	PP	-	50%	-	-
[D-NEG] Datos gestión del negocio	[E.18] Destrucción de la información	PP	100%	-	-	-
[D-DISCO] Discos clientes reparac.	[A.19] Revelación de información	MP	-	-	75%	-
[D-DISCO] Discos clientes reparac.	[PR.2n] Accesos no autorizados (lectura) - RGPD	P	-	-	100%	-
[IS-BACK] Copias de seguridad	[E.15] Alteración de la información	MP	-	75%	-	-
[IS-ACC] Acceso remoto gerente	[A.5] Suplantación de la identidad	P	-	-	75%	-
[SW-OS1] Windows 7 PC1	[E.20] Vulnerabilidades de los programas (software)	MP	-	50%	50%	-
[SW-OS2] Windows 7 PC2	[E.20] Vulnerabilidades de los programas (software)	MP	-	50%	50%	-

[SW-DEF] Windows Defender	[E.20] Vulnerabilidades de los programas (software)	MP	-	50%	50%	-
[HW-PC1] Ordenador 1	[A.11] Acceso no autorizado	P	-	75%	75%	-
[HW-PC1] Ordenador 1	[A.25] Robo de equipos	P	100%	-	100%	-
[HW-PC2] Ordenador 2	[A.11] Acceso no autorizado	P	-	50%	50%	-
[HW-USB] Disco duro externo USB	[A.25] Robo de equipos	P	100%	-	100%	-
[COM-WIFI] Red WiFi local	[E.2] Errores del administrador del sistema	MP	-	50%	50%	-
[COM-WIFI] Red WiFi local	[A.11] Acceso no autorizado	P	-	50%	75%	100%
[COM-VPN] VPN PPTP	[A.5] Suplantación de la identidad	P	-	-	-	75%
[COM-INT] Conexión a Internet	[E.24] Caída del sistema por agotamiento de recursos	PP	50%	-	-	-
[AUX-USB] Cajón disco USB	[A.25] Robo de equipos	P	100%	-	-	-
[AUX-MOB] Mobiliario del local	[I.2] Daños por agua	MR	50%	-	-	-
[L-LOC] Local comercial	[A.26] Ataque destructivo	P	100%	-	-	-
[L-TALL] Zona taller reparaciones	[A.11] Acceso no autorizado	P	-	-	75%	-
[L-RECEP] Zona de recepción	[A.25] Robo de equipos	P	75%	-	-	-
[P-GER] Gerente	[A.28] Indisponibilidad del personal	PP	50%	-	-	-
[P-TEC] Técnicos (x2)	[A.28] Indisponibilidad del personal	PP	75%	-	-	-

activo	co...	probabilidad	[D]	[I]	[C]	[A]	[T]	[DP]
ACTIVOS								
[B] Activos esenciales								
[SI-MACRO] Sistema de Información de MACROSOFT S.L.								
[S-VENTA] Servicio de venta de equipos y componentes			50%					
[E.24] Caída del sistema por agotamiento de recursos		PP	50%					
[S-REPAR] Servicio de reparación de equipos y móviles			75%					
[A.28] Indisponibilidad del personal		PP	75%					
[D-CLI] Datos de clientes (nombre, teléfono, pedidos)					100%			
[E.19] Fugas de información		MP			75%			
[PR.g18] 18. Seleccionar o mantener una relación con un encarga		P			100%			
[D-PROV] Datos de proveedores y pedidos				50%				
[E.15] Alteración de la información		PP		50%				
[D-NEG] Datos de gestión del negocio (ventas, facturación)			100%					
[E.18] Destrucción de la información		PP	100%					
[D-DISCO] Datos en discos duros de clientes en reparación					100%			
[A.19] Revelación de información		MP			75%			
[PR.2n] Accesos no autorizados a datos personales (lectura)		P			100%			
[IS] Servicios internos								
[IS-BACK] Gestión de copias de seguridad				75%				
[E.15] Alteración de la información		MP		75%				
[IS-ACC] Gestión de acceso remoto del gerente					75%			
[A.5] Suplantación de la identidad		P			75%			
[E] Equipamiento								
[SW] Aplicaciones								
[SW-OS1] Windows 7 PC1				50%	50%			
[E.28] Vulnerabilidades de los programas (software)		MP		50%	50%			
[SW-OS2] Windows 7 PC1				50%	50%			
[E.28] Vulnerabilidades de los programas (software)		MP		50%	50%			
[SW-DEF] Windows Defender				50%	50%			
[E.28] Vulnerabilidades de los programas (software)		MP		50%	50%			
[HW] Equipos								
[HW-PC1] Ordenador 1 (gestión y datos)			100%	75%	100%			
[A.11] Acceso no autorizado		P		75%	75%			
[A.25] Robo de equipos		P	100%		100%			
[HW-PC2] Ordenador 2 (acceso por red)				50%	50%			
[A.11] Acceso no autorizado		P		50%	50%			
[HW-USB] Disco duro externo USB			100%		100%			
[A.25] Robo de equipos		P	100%		100%			
[COM] Comunicaciones								
[COM-WIFI] Red WiFi local				50%	75%	100%		
[E.2] Errores del administrador del sistema / de la seguridad		MP		50%	50%			
[A.11] Acceso no autorizado		P		50%	75%	100%		
[COM-VPN] VPN PPTP acceso remoto gerente						75%		
[A.5] Suplantación de la identidad		P				75%		
[COM-INT] Conexión a Internet			50%					
[E.24] Caída del sistema por agotamiento de recursos		PP	50%					
[AUX] Elementos auxiliares								
[AUX-USB] Cajón donde se guarda el disco USB			100%					
[A.25] Robo de equipos		P	100%					
[AUX-MOB] Mobiliario del local			50%					
[I.2] Daños por agua		MR	50%					

activo	co...	probabilidad	[D]	[I]	[C]	[A]	[T]	[DP]
ACTIVOS								
[B] Activos esenciales								
[IS] Servicios internos								
[E] Equipamiento								
[SS] Servicios subcontratados								
[IL] Instalaciones								
[IL-LOC] Local comercial			100%					
[A.26] Ataque destructivo		P	100%					
[IL-TALL] Zona de taller de reparaciones					75%			
[A.11] Acceso no autorizado		P			75%			
[IL-RECEP] Zona de recepción y atención al cliente			75%					
[A.25] Robo de equipos		P	75%					
[P] Personal								
[P-GER] Gerente			50%					
[A.28] Indisponibilidad del personal		PP	50%					
[P-TEC] Técnicos (x2)			75%					
[A.28] Indisponibilidad del personal		PP	75%					

9. Análisis de riesgos

A continuación, se presenta la tabla de riesgos acumulados obtenida de PILAR, ordenada de mayor a menor. Se analizan en detalle los cinco riesgos más significativos para la organización.

potencial	current	target	PILAR	resumen (impacto)	resumen (riesgo)
activo	amenaza	dimensión	current	target	PILAR
[SW-OS1] Windows 7 PC1	[E.20] Vulnerabilidades de los programas (so...	[C]	(5,4)	(5,4)	(2,5)
[SW-OS2] Windows 7 PC1	[E.20] Vulnerabilidades de los programas (so...	[C]	(5,4)	(5,4)	(2,5)
[SW-DEF] Windows Defender	[E.20] Vulnerabilidades de los programas (so...	[C]	(5,4)	(5,4)	(2,5)
[COM-WIFI] Red WiFi local	[E.2] Errores del administrador del sistema / ...	[C]	(5,4)	(5,4)	(2,3)
[ID-CLI] Datos de clientes (nombre, teléfono, ...	[E.19] Fugas de información	[C]	(5,3)	(5,3)	(2,3)
[ID-DISCO] Datos en discos duros de clientes ...	[A.19] Revelación de información	[C]	(5,1)	(5,1)	(2,2)
[HW-PC1] Ordenador 1 (gestión y datos)	[A.25] Robo de equipos	[C]	(4,8)	(4,8)	(1,5)
[HW-PC1] Ordenador 1 (gestión y datos)	[A.11] Acceso no autorizado	[C]	(4,8)	(4,8)	(1,5)
[COM-WIFI] Red WiFi local	[A.11] Acceso no autorizado	[C]	(4,8)	(4,8)	(1,7)
[SW-OS1] Windows 7 PC1	[E.20] Vulnerabilidades de los programas (so...	[I]	(4,8)	(4,8)	(1,5)
[SW-OS2] Windows 7 PC1	[E.20] Vulnerabilidades de los programas (so...	[I]	(4,8)	(4,8)	(1,5)
[SW-DEF] Windows Defender	[E.20] Vulnerabilidades de los programas (so...	[I]	(4,8)	(4,8)	(1,5)
[COM-WIFI] Red WiFi local	[E.2] Errores del administrador del sistema / ...	[I]	(4,8)	(4,8)	(1,7)
[ID-CLI] Datos de clientes (nombre, teléfono, ...	[PR.g10] 10. Seleccionar o mantener una relac...	[C]	(4,7)	(4,7)	(4,7)
[IL-TALL] Zona de taller de reparaciones	[A.11] Acceso no autorizado	[C]	(4,6)	(4,6)	(1,6)
[HW-PC2] Ordenador 2 (acceso por red)	[A.11] Acceso no autorizado	[C]	(4,5)	(4,5)	(1,5)
[IL-LOC] Local comercial	[A.26] Ataque destructivo	[D]	(4,5)	(4,5)	(1,7)
[ID-DISCO] Datos en discos duros de clientes ...	[PR.2n] Accesos no autorizados a datos pers...	[C]	(4,5)	(4,5)	(4,5)
[IS-ACC] Gestión de acceso remoto del gere...	[A.5] Suplantación de la identidad	[C]	(4,3)	(4,3)	(1,4)
[HW-PC1] Ordenador 1 (gestión y datos)	[A.25] Robo de equipos	[D]	(4,2)	(4,2)	(1,2)
[HW-PC1] Ordenador 1 (gestión y datos)	[A.11] Acceso no autorizado	[I]	(4,2)	(4,2)	(1,2)
[IS-BACK] Gestión de copias de seguridad	[E.15] Alteración de la información	[I]	(4,1)	(4,1)	(1,2)
[HW-PC2] Ordenador 2 (acceso por red)	[A.11] Acceso no autorizado	[I]	(3,9)	(3,9)	(0,97)
[COM-WIFI] Red WiFi local	[A.11] Acceso no autorizado	[I]	(3,9)	(3,9)	(0,95)
[COM-WIFI] Red WiFi local	[A.11] Acceso no autorizado	[A]	(3,8)	(3,8)	(0,94)
[HW-USB] Disco duro externo USB	[A.25] Robo de equipos	[C]	(3,7)	(3,7)	(0,97)
[IL-RECEP] Zona de recepción y atención al cli...	[A.25] Robo de equipos	[D]	(3,7)	(3,7)	(0,93)
[P-TEC] Técnicos (x2)	[A.28] Indisponibilidad del personal	[D]	(3,2)	(3,2)	(0,86)
[HW-USB] Disco duro externo USB	[A.25] Robo de equipos	[D]	(3,2)	(3,2)	(0,84)
[AUX-USB] Cajón donde se guarda el disco USB	[A.25] Robo de equipos	[D]	(3,2)	(3,2)	(0,82)
[COM-VPN] VPN PPTP acceso remoto gerente	[A.5] Suplantación de la identidad	[A]	(3,1)	(3,1)	(0,81)
[ID-NEG] Datos de gestión del negocio (ventas...	[E.18] Destrucción de la información	[D]	(3,0)	(3,0)	(0,79)
[S-REPAR] Servicio de reparación de equipos ...	[A.28] Indisponibilidad del personal	[D]	(2,8)	(2,8)	(0,79)
[P-GER] Gerente	[A.28] Indisponibilidad del personal	[D]	(2,8)	(2,8)	(0,78)
[S-VENTA] Servicio de venta de equipos y co...	[E.24] Caída del sistema por agotamiento de r...	[D]	(2,5)	(2,5)	(0,70)
[COM-INT] Conexión a Internet	[E.24] Caída del sistema por agotamiento de r...	[D]	(2,5)	(2,5)	(0,70)
[D-PROV] Datos de proveedores y pedidos	[E.15] Alteración de la información	[I]	(2,0)	(2,0)	(0,60)
[AUX-MOB] Mobiliario del local	[L.2] Daños por agua	[D]	(1,7)	(1,7)	(0,60)

Riesgo 1 — WiFi insegura: Acceso no autorizado a la red

Activo (hijo)	Amenaza	Dimensión	Riesgo
COM-WIFI Red WiFi local	A.11 Acceso no autorizado	[C] [I] [A]	{5,5}

Vulnerabilidad: La red WiFi utiliza WPA2-PSK con SSID y contraseña maestra por defecto, tal como la instaló el proveedor de Internet, con WPS activado. Cualquier atacante desde el exterior del local puede comprometer la red con herramientas gratuitas (Reaver para WPS) y acceder a todos los equipos y datos del negocio. El PC2 solo puede acceder a los datos a través de esta red, por lo que su compromiso afecta directamente a la confidencialidad e integridad de toda la información.

CONTROL ISO 27001:2022 A APLICAR:

8.20 Seguridad de redes | 8.5 Autenticación segura

Recomendación: Cambiar inmediatamente la contraseña WiFi por una contraseña robusta de mínimo 16 caracteres (combinación de letras, números y símbolos). Desactivar WPS. Cambiar el SSID por un nombre que no identifique el negocio. Si es posible, migrar a WPA3. Revisar periódicamente los dispositivos conectados a la red.

Riesgo 2 — Incumplimiento RGPD: Acceso a discos de clientes sin contrato

Activo (hijo)	Amenaza	Dimensión	Riesgo
D-DISCO Datos en discos de clientes	PR.2n Accesos no autorizados a datos personales - RGPD	[C]	{5,0}

Vulnerabilidad: Al reparar equipos, los técnicos tienen acceso total a los discos duros de los clientes, que pueden contener fotos personales, documentos bancarios, contraseñas guardadas en navegadores y otro tipo de información privada. No existe contrato de encargado de tratamiento firmado con los clientes (Art. 28 RGPD), ni procedimiento que limite el acceso de los técnicos a lo estrictamente necesario para la reparación. Esto constituye una infracción directa del RGPD que puede acarrear sanciones de hasta 10 millones de euros o el 2% de la facturación global.

CONTROL RGPD + ISO 27001:2022 A APLICAR:

Art. 28 RGPD (Contrato encargado de tratamiento) | 5.14 Transferencia de información | 5.33 Protección de registros.

Riesgo 3 — Windows 7 sin soporte: Vulnerabilidades del software

Activo (hijo)	Amenaza	Dimensión	Riesgo
SW-OS1 / SW-OS2 Windows 7 PC1 y PC2	E.20 Vulnerabilidades de los programas	[C] [I]	{4,0}

Vulnerabilidad: Windows 7 perdió el soporte oficial de Microsoft en enero de 2020. Desde esa fecha no recibe parches de seguridad, dejando los sistemas expuestos a todas las vulnerabilidades descubiertas posteriormente. Windows Defender en W7 tampoco recibe actualizaciones de firmas de malware, por lo que la protección antimalware es prácticamente nula contra amenazas modernas. Esta combinación hace que ambos equipos sean extremadamente vulnerables a ransomware, exploits conocidos y malware actual.

CONTROL ISO 27001:2022 A APLICAR:

8.1 Dispositivos finales de usuario | 8.8 Gestión de vulnerabilidades técnicas | 8.7 Controles contra el código malicioso.

Recomendación: Migrar ambos equipos a Windows 10 o Windows 11 a la mayor brevedad posible. Mientras se realiza la migración, instalar un antivirus de terceros con soporte activo para W7 (ej. ESET o Bitdefender) y desconectar los equipos de Internet

cuando no sea estrictamente necesario. Una vez migrados, activar las actualizaciones automáticas del sistema operativo.

Riesgo 4 — VPN PPTP: Suplantación de identidad en acceso remoto

Activo (hijo)	Amenaza	Dimensión	Riesgo
COM-VPN VPN PPTP gerente	A.5 Suplantación de la identidad	[A]	{4,2}

Vulnerabilidad: El protocolo PPTP tiene vulnerabilidades críticas conocidas desde hace años: MS-CHAPv2, el mecanismo de autenticación utilizado por PPTP, fue roto públicamente en 2012 y puede descifrarse con herramientas accesibles. Además, el PC del gerente en su domicilio es utilizado también por otros miembros de su familia que instalan software sin verificar su procedencia, aumentando el riesgo de que el equipo esté infectado con malware que capture credenciales.

CONTROL ISO 27001:2022 A APLICAR:

8.5 Autenticación segura | 6.7 Teletrabajo.

Recomendación: Migrar la VPN al protocolo OpenVPN o WireGuard, que son seguros y gratuitos. Implementar autenticación de dos factores para el acceso remoto. Proporcionar al gerente un dispositivo corporativo dedicado exclusivamente al acceso remoto al negocio, o al menos una cuenta de usuario separada con perfil de seguridad reforzado.

Riesgo 5 — Sin alarma ni cámaras: Robo físico en zona de riesgo

Activo (hijo)	Amenaza	Dimensión	Riesgo
L-LOC Local comercial	A.26 Ataque destructivo / Robo	[D]	{3,8}
HW-PC1 Ordenador 1	A.25 Robo de equipos	[C] [D]	{4,5}

Vulnerabilidad: El local está ubicado en La Coma (Paterna), zona con alto índice de delincuencia. No dispone de alarma central ni cámaras de vigilancia. PC1, que contiene todos los datos del negocio sin cifrado de disco, está en el local sin ningún tipo de anclaje físico. En caso de robo, el atacante obtendría acceso total a todos los datos de clientes, datos contables, contraseñas y demás información sensible. Las copias de seguridad

también están en el mismo local, por lo que un robo eliminaría tanto los datos originales como las copias.

CONTROL ISO 27001:2022 A APLICAR:

7.2 Controles físicos de entrada | 7.4 Monitorización de la seguridad física | 8.24 Uso de la criptografía | 8.13 Copias de seguridad.

Recomendación: Instalar alarma central conectada a empresa de seguridad y cámaras IP en la entrada y zona de trabajo. Anclar físicamente los equipos a los muebles con cable de seguridad. Activar cifrado de disco completo en PC1 (BitLocker). Guardar una copia de los datos fuera del local (nube cifrada o domicilio del gerente) para evitar que un robo físico implique también la pérdida total de los datos.

Exportar							
potencial		current	target	PILAR	resumen (impacto)	resumen (riesgo)	
activo	amenaza	dimensión	riesgo	current	target	PILAR	
[SW-OS1] Windows 7 PC1	[E.20] Vulnerabilidades de los programas (so...	[C]	(5,4)	(5,4)	(5,4)	(2,5)	
[SW-OS2] Windows 7 PC1	[E.20] Vulnerabilidades de los programas (so...	[C]	(5,4)	(5,4)	(5,4)	(2,5)	
[SW-DEF] Windows Defender	[E.20] Vulnerabilidades de los programas (so...	[C]	(5,4)	(5,4)	(5,4)	(2,5)	
[COM-WIFI] Red WiFi local	[E.2] Errores del administrador del sistema / ...	[C]	(5,4)	(5,4)	(5,4)	(2,3)	
[ID-CLI] Datos de clientes (nombre, teléfono, ...	[E.19] Fugas de información	[C]	(5,3)	(5,3)	(5,3)	(2,3)	
[ID-DISCO] Datos en discos duros de clientes ...	[A.19] Revelación de información	[C]	(5,1)	(5,1)	(5,1)	(2,2)	
[HW-PC1] Ordenador 1 (gestión y datos)	[A.25] Robo de equipos	[C]	(4,8)	(4,8)	(4,8)	(1,9)	
[HW-PC1] Ordenador 1 (gestión y datos)	[A.11] Acceso no autorizado	[C]	(4,8)	(4,8)	(4,8)	(1,8)	
[COM-WIFI] Red WiFi local	[A.11] Acceso no autorizado	[C]	(4,8)	(4,8)	(4,8)	(1,7)	
[SW-OS1] Windows 7 PC1	[E.20] Vulnerabilidades de los programas (so...	[I]	(4,8)	(4,8)	(4,8)	(1,9)	
[SW-OS2] Windows 7 PC1	[E.20] Vulnerabilidades de los programas (so...	[I]	(4,8)	(4,8)	(4,8)	(1,9)	
[SW-DEF] Windows Defender	[E.20] Vulnerabilidades de los programas (so...	[I]	(4,8)	(4,8)	(4,8)	(1,9)	
[COM-WIFI] Red WiFi local	[E.2] Errores del administrador del sistema / ...	[I]	(4,8)	(4,8)	(4,8)	(1,7)	
[ID-CLI] Datos de clientes (nombre, teléfono, ...	[PR.g18] 18. Seleccionar o mantener una relac...	[C]	(4,7)	(4,7)	(4,7)	(4,7)	
[IL-TALL] Zona de taller de reparaciones	[A.11] Acceso no autorizado	[C]	(4,6)	(4,6)	(4,6)	(1,6)	
[HW-PC2] Ordenador 2 (acceso por red)	[A.11] Acceso no autorizado	[C]	(4,5)	(4,5)	(4,5)	(1,5)	
[IL-LOC] Local comercial	[A.26] Ataque destructivo	[D]	(4,5)	(4,5)	(4,5)	(1,7)	
[ID-DISCO] Datos en discos duros de clientes ...	[PR.2n] Accesos no autorizados a datos pers...	[C]	(4,5)	(4,5)	(4,5)	(4,5)	
[IS-ACC] Gestión de acceso remoto del gere...	[A.5] Suplantación de la identidad	[C]	(4,3)	(4,3)	(4,3)	(1,4)	
[HW-PC1] Ordenador 1 (gestión y datos)	[A.25] Robo de equipos	[D]	(4,2)	(4,2)	(4,2)	(1,2)	
[HW-PC1] Ordenador 1 (gestión y datos)	[A.11] Acceso no autorizado	[I]	(4,2)	(4,2)	(4,2)	(1,2)	
[IS-BACK] Gestión de copias de seguridad	[E.15] Alteración de la información	[I]	(4,1)	(4,1)	(4,1)	(1,2)	
[HW-PC2] Ordenador 2 (acceso por red)	[A.11] Acceso no autorizado	[I]	(3,9)	(3,9)	(3,9)	(0,97)	
[COM-WIFI] Red WiFi local	[A.11] Acceso no autorizado	[I]	(3,9)	(3,9)	(3,9)	(0,95)	
[COM-WIFI] Red WiFi local	[A.11] Acceso no autorizado	[I]	(3,8)	(3,8)	(3,8)	(0,94)	
[HW-USB] Disco duro externo USB	[A.25] Robo de equipos	[C]	(3,7)	(3,7)	(3,7)	(0,97)	
[IL-RECEP] Zona de recepción y atención al cli...	[A.25] Robo de equipos	[D]	(3,7)	(3,7)	(3,7)	(0,93)	
[P-TEC] Técnicos (x2)	[A.28] Indisponibilidad del personal	[D]	(3,2)	(3,2)	(3,2)	(0,86)	
[HW-USB] Disco duro externo USB	[A.25] Robo de equipos	[D]	(3,2)	(3,2)	(3,2)	(0,84)	
[AUX-USB] Cajón donde se guarda el disco USB	[A.25] Robo de equipos	[D]	(3,2)	(3,2)	(3,2)	(0,82)	
[COM-VPN] VPN PPTP acceso remoto gerente	[A.5] Suplantación de la identidad	[A]	(3,1)	(3,1)	(3,1)	(0,81)	
[ID-NEG] Datos de gestión del negocio (ventas...	[E.18] Destrucción de la información	[D]	(3,0)	(3,0)	(3,0)	(0,79)	
[S-REPAR] Servicio de reparación de equipos ...	[A.28] Indisponibilidad del personal	[D]	(2,8)	(2,8)	(2,8)	(0,79)	
[P-GER] Gerente	[A.28] Indisponibilidad del personal	[D]	(2,8)	(2,8)	(2,8)	(0,78)	
[S-VENTA] Servicio de venta de equipos y co...	[E.24] Caída del sistema por agotamiento de r...	[D]	(2,5)	(2,5)	(2,5)	(0,70)	
[COM-INT] Conexión a Internet	[E.24] Caída del sistema por agotamiento de r...	[D]	(2,5)	(2,5)	(2,5)	(0,70)	
[ID-PROV] Datos de proveedores y pedidos	[E.15] Alteración de la información	[I]	(2,0)	(2,0)	(2,0)	(0,60)	
[AUX-MOB] Mobiliario del local	[L.2] Daños por agua	[D]	(1,7)	(1,7)	(1,7)	(0,60)	

10. Análisis de impacto

Confidencialidad

El análisis de impacto refleja el daño potencial que cada amenaza causaría en el sistema de información de **MACROSOFT S.L.** si se materializase, con independencia de su probabilidad de ocurrencia. Se calcula como el producto del valor del activo por la degradación que la amenaza produciría en cada dimensión de seguridad (**D, I, C, A, T**). Los valores se expresan en la escala cualitativa de PILAR (1-10), donde valores iguales o superiores a [6] indican impacto alto y valores de [7] o superior indican impacto crítico. Los activos con mayor impacto son aquellos que concentran datos de mayor valor (HW-PC1 como punto único de fallo, D-CLI y D-DISCO por su naturaleza de datos personales) o que afectan a toda la infraestructura de comunicaciones (COM-WIFI). La dimensión de confidencialidad [C] es la más impactada, con el activo padre SI-MACRO alcanzando un nivel [7], lo que refleja la gravedad de las vulnerabilidades en el manejo de datos personales de clientes y discos en reparación.

[MACRO] A.4.2. Valores repercutid ... > A.4.2.1. impacto							
Exportar							
potencial		current	target	PILAR			
activo		[D]	[I]	[C]	[A]	[T]	[DP]
ACTIVOS							
[SI-MACRO] Sistema de información de MACROSOFT S.L.		[6]	[6]	[7]	[5]		
[D] disponibilidad		[6]					
[S-VENTA] Servicio de venta de equipos y componentes		[4]					
[S-REPAR] Servicio de reparación de equipos y móviles		[5]					
[B-HFG] Datos de gestión del negocio (ventas, facturación)		[5]					
[HW-PC1] Ordenador 1 (gestión y datos)		[6]					
[COM-INT] Conexión a Internet		[4]					
[AUX-MOB] Cajón donde se guarda el disco USB		[4]					
[L-LOC] Local comercial		[6]					
[P-GER] Gerente		[5]					
[P-TEC] Técnicos (x2)		[5]					
[I] integridad de los datos			[6]				
[B-PROV] Datos de proveedores y pedidos			[3]				
[IS-BACK] Gestión de copias de seguridad			[4]				
[SW-OS1] Windows 7 PC1			[5]				
[SW-OS2] Windows 7 PC1			[5]				
[SW-DEF] Windows Defender			[5]				
[HW-PC1] Ordenador 1 (gestión y datos)			[6]				
[HW-PC2] Ordenador 2 (acceso por red)			[5]				
[COM-WIFI] Red WIFI local			[5]				
[C] confidencialidad de los datos				[7]			
[D-CLI] Datos de clientes (nombre, teléfono, pedidos)				[6]			
[D-DISCO] Datos en discos duros de clientes en reparación				[6]			
[IS-ACC] Gestión de acceso remoto del gerente				[6]			
[SW-OS1] Windows 7 PC1				[6]			
[SW-OS2] Windows 7 PC1				[6]			
[SW-DEF] Windows Defender				[6]			
[HW-PC1] Ordenador 1 (gestión y datos)				[7]			
[HW-PC2] Ordenador 2 (acceso por red)				[6]			
[HW-USB] Disco duro externo USB				[5]			
[COM-WIFI] Red WIFI local				[7]			
[L-TALL] Zona de taller de reparaciones				[6]			
[A] autenticidad de los usuarios y de la información					[5]		
[COM-WIFI] Red WIFI local					[5]		
[COM-VPN] VPN PPTP acceso remoto gerente					[4]		
[T] trazabilidad del servicio y de los datos							

Confidencialidad [C] — Impacto crítico

Es la dimensión más impactada. HW-PC1 y COM-WIFI alcanzan nivel [7] (crítico), ya que un compromiso de estos activos expone la totalidad de los datos del negocio. D-CLI, D-DISCO, IS-ACC, SW-OS1, SW-OS2, SW-DEF, HW-PC2 y L-TALL presentan nivel [6] (alto). El riesgo de confidencialidad es especialmente grave dado que MACROSOFT S.L. gestiona datos personales de clientes y discos en reparación con información privada de terceros, lo que implica responsabilidad directa bajo el RGPD.

Disponibilidad [D] — Impacto alto en activos físicos

HW-PC1 y L-LOC alcanzan nivel [6]. HW-PC1 es el punto único de fallo de toda la operativa: su pérdida o robo paralizaría ventas y reparaciones. L-LOC con nivel [6] refleja que un ataque destructivo (robo, vandalismo) en un local sin alarma ni cámaras podría destruir todos los activos físicos. S-REPAR, D-NEG, L-RECEP, P-GER y P-TEC alcanzan nivel [5].

Integridad [I] — Impacto alto en HW-PC1

HW-PC1 alcanza nivel [6] en integridad. Si un atacante con acceso no autorizado modifica datos de clientes, pedidos o facturas almacenados en PC1, el impacto sobre la integridad del negocio es alto. SW-OS1, SW-OS2, SW-DEF, HW-PC2 y COM-WIFI presentan nivel [5]. IS-BACK tiene nivel [4], evidenciando que la irregularidad en las copias compromete también la integridad de los datos respaldados.

Autenticidad [A] — Impacto medio en comunicaciones

COM-WIFI alcanza nivel [5] en autenticidad. La red WiFi con WPS activo y credenciales por defecto permite suplantación de dispositivos en la red local. COM-VPN presenta nivel [4] por la vulnerabilidad del protocolo PPTP (MS-CHAPv2), que permite a un atacante suplantar al gerente en el acceso remoto.

Conclusión del análisis

El análisis de impacto evidencia que **MACROSOFT S.L.** concentra sus mayores riesgos en tres vectores principales: **(1)** la confidencialidad de los datos personales de clientes, cuya exposición supone impacto legal (RGPD) y reputacional; **(2)** la disponibilidad de HW-PC1, único punto de fallo para toda la operativa; y **(3)** la red WiFi, cuyo compromiso afectaría simultáneamente a confidencialidad, integridad y autenticidad de todas las comunicaciones internas. Estos tres vectores deben ser prioritarios en la selección de salvaguardas.

11. Salvaguardas

Se han seleccionado los controles más adecuados para mitigar los riesgos identificados: 2 controles RGPD (obligatorios por tratarse de datos de carácter personal) y 13 controles ISO/IEC 27001:2022. Se puede ver más información en la tabla excel adjuntada.

Controles RGPD obligatorios

Código	Control	Implementación en MICROSOFT
Art. 28 RGPD	Contrato de encargado de tratamiento	Firmar contrato con clientes antes de manipular su dispositivo. Incluir limitación de uso, confidencialidad y borrado tras reparación.
Art. 25 RGPD	Privacidad por diseño y por defecto	Limitar el acceso de los técnicos solo a lo necesario para la reparación. Procedimiento que prohíbe copiar datos del cliente.

Controles ISO/IEC 27001:2022

Control	Nombre	Implementación en MICROSOFT
5.1	Políticas de seguridad	Redactar política básica de seguridad y comunicarla a gerente y técnicos
5.15	Control de acceso	Crear cuentas individuales con contraseña. Eliminar cuentas genéricas compartidas.
5.17	Información de autenticación	Política de contraseñas: mínimo 12 caracteres, cambio cada 90 días
5.33	Protección de registros	Libro de registro de dispositivos recibidos: técnico, fecha de entrada y salida
6.3	Concienciación y formación	Sesión formativa básica para técnicos sobre RGPD y ciberseguridad
7.2	Controles físicos de entrada	Instalar alarma central + cámaras IP. Anclar equipos a muebles.
8.1	Dispositivos finales de usuario	Migrar de Windows 7 a W10/W11. Activar actualizaciones automáticas.
8.5	Autenticación segura	Cambiar credenciales WiFi, desactivar WPS. Migrar VPN de PPTP a OpenVPN.
8.7	Controles contra código malicioso	Instalar antivirus profesional con soporte activo. Análisis semanal programado.
8.8	Gestión de vulnerabilidades	Proceso de parcheo: aplicar actualizaciones en máximo 30 días tras publicación.
8.13	Copias de seguridad	Automatizar backups semanales. Copia adicional fuera del local. Verificar restauración mensualmente.
8.20	Seguridad de redes	Reconfigurar router WiFi con credenciales robustas. Desactivar WPS. Activar firewall.
8.24	Uso de la criptografía	Cifrar disco USB con BitLocker To Go. Cifrado de disco completo en PC1.
5.24	Gestión de incidentes de seguridad	Establecer canal de notificación de incidentes (robo, acceso no autorizado, pérdida de datos).

7.7	Escritorio y pantalla limpios	Política de puesto despejado: guardar el disco USB de backup en lugar con cerradura (no en cajón abierto AUX-USB).
-----	-------------------------------	--

Base Base					sólo si ...								
	aspecto	tdp	recomendación	nivel	salvaguarda	dudas	fuentes	aplica	comentario	current	target	PIA AB	
☐	G	EL	8		SALVAGUARDAS							L2-L5	
☐	G	STD	2		1.3 [IA.1] Identificación y autenticación							L2-L4	
☐	G	PROC	2		1.1 [IA.1] Se dispone de normativa de identificación y autenticación [IA-1]							L2	
☐	G	EL	3		1.1 [IA.2] Se dispone de procedimientos para las tareas de identificación y autenticación [IA-1]							L2	
☐	G	EL	3		1.1 [IA.3] Identificación de los usuarios							L3	
☐	G	EL	3		1.3 [IA.3.1] Cada usuario recibe un identificador exclusivo (no compartido)							L3	
☐	G	EL	3		1.3 [IA.3.2] La identificación del usuario no indica ni su función ni su nivel de privilegios							L3	
☐	T	EL	3		1.3 [IA.3.3] Las cuentas de invitados están sometidas a un control estricto							L3	
☐	T	EL	3		1.3 [IA.3.4] Se identifican las personas que actúan como usuarios							L3	
☐	T	EL	3		1.3 [IA.3.5] Se identifican los procesos software que actúan como usuarios							L3	
☐	G	EL	3		1.1 [IA.4] Gestión de la identificación y autenticación de usuario							L2-L3	
☐	G	EL	4		1.2 [IA.5] Cuentas especiales (administración)							L2-L3	
☐	G	PR	7		1.3 [IA.6] El mecanismo de autenticación se inhabilita cuando se ve comprometido o hay sospecha de ello							L4	
☐	T	EL	4		1.3 [IA.7] Canal seguro de autenticación [SC-11]							L3	
☐	G	EL	8		1.3 [IA.8] (xor) Nivel de garantía de la autenticación							L3	
☐	G	EL	3		1.1 [IA.9] Biometría - Algo que eres							L3	
☐	G				1.1 Mecanismo de autenticación (NIST SP 800-63)								
☐	T	EL	7		1.3 [AC] Control de acceso lógico							L2-L4	
☐	G	PR	4		1.3 [D] Protección de la Información							L2-L3	
☐	G	EL			1.3 [K] Protección de claves criptográficas [SC-12]							n.a.	
☐	G	PR	3		1.3 [S] Protección de los Servicios							L2-L3	
☐	G	PR	4		1.3 [SW] Protección de las Aplicaciones Informáticas (SW)							L2-L3	
☐	G	PR	4		1.3 [HW] Protección de los Equipos Informáticos (HW)							L2-L3	
☐	G	PR	8		1.3 [COM] Protección de las Comunicaciones							L2-L6	
☐	G	PR			1.3 [M] Protección de los Soportes de Información							n.a.	
☐	G	PR	5		1.3 [AUX] Elementos Auxiliares							L2-L3	
☐	F	EL	5		1.3 [PPE] Protección física de los equipos							L3	
☐	F	PR	4		1.3 [L] Protección de las Instalaciones							L2-L3	
☐	P	PR	3		1.3 [P] Gestión del Personal							L2-L3	
☐	G	CR	4		1.3 [IM] Gestión de incidentes							L2-L3	
☐	T	PR	7		1.3 [tools] Herramientas de seguridad							L2-L4	
☐	G	CR	3		1.3 [V] Gestión de vulnerabilidades							L2-L3	
☐	T	MN			1.3 [A] Registro y auditoría							n.a.	
☐	G	RC	2		1.3 [BC] Continuidad del negocio							L2	
☐	G	AD	4		1.3 [G] Organización							L2-L3	
☐	G	AD	3		1.3 [E] Relaciones Externas							L2-L3	
☐	G	AD	4		1.3 [NBW] Adquisición / desarrollo							L2-L3	
☐	G	PR			1.3 [PDS] Servicios potencialmente peligrosos							n.a.	
☐	G	PR			1.3 [PI] Sistema de protección de frontera lógica							n.a.	
☐	F	EL			1.3 [PPS] Protección del perímetro físico							n.a.	
☐	G	EL			1.3 [TEMPEST] Protección de emanaciones (TEMPEST) [PE-19]							n.a.	

12. Conclusión

El análisis de riesgos realizado con PILAR sobre MACROSOFT S.L. pone de manifiesto que la principal vulnerabilidad de la organización no es tecnológica sino organizativa: la ausencia de políticas básicas de seguridad, el uso de software sin soporte, credenciales por defecto sin cambiar y la inexistencia de contratos de encargado de tratamiento con los clientes generan una superficie de ataque amplia con recursos mínimos para el atacante.

La dimensión más comprometida es la confidencialidad, especialmente en lo relativo al manejo de datos personales de clientes y discos en reparación, lo que sitúa a la empresa en una situación de incumplimiento directo del RGPD con riesgo de sanción.

Las salvaguardas propuestas priorizan medidas de alto impacto y bajo coste: securización de la red WiFi, migración del sistema operativo, automatización de copias de seguridad, control de acceso individual y formalización del tratamiento de datos personales. Su implementación es completamente viable para una microempresa del tamaño de MACROSOFT S.L. y reduciría el riesgo residual de los activos más críticos a niveles aceptables.